SANITIZED PORTFOLIO SAMPLE

AWS SECURITY POSTURE REVIEW

Engineering Remediation Report

Detailed AWS-native remediation and verification guide for the confirmed findings in this point-in-time assessment.

PREPARED FOR

ACME CORPORATION

AWS Account: 123456789012
Assessment: ASC-SAMPLE-2026-001
Prepared: October 12, 2026

Example Security Provider
Point-in-time, read-only AWS security posture assessment

ENGINEERING REMEDIATION REPORT

AWS Security Posture Review

Detailed AWS-native remediation and verification guide for the confirmed findings in this point-in-time assessment.

ACME CORPORATION

AWS ACCOUNT	ASSESSMENT	PREPARED
123456789012	ASC-SAMPLE-2026-001	**October 12, 2026**

CONTROLS EVALUATED	CONFIRMED FINDINGS	PASSED
9	3	6

How to use this report

Work confirmed findings from highest severity downward. Each confirmed finding begins on a new page and continues naturally as needed. The AWS Console procedure is the recommended default. Advanced CLI/CloudShell options appear only when they add useful repeatability or capability. Every runbook also includes preparation checks, ordered remediation steps, important considerations, AWS-side verification, assessment success criteria, and official AWS guidance.

EXECUTION PLAN

Remediation Roadmap

1. HIGH - CloudTrail multi-region trail is not enabled

Detection | Estimated effort: medium

2. HIGH - IAM account password policy is not configured

Identity and access management | Estimated effort: low

3. HIGH - S3 account-level Block Public Access is not configured

Data protection | Estimated effort: low

ENGINEERING FINDING 1 OF 3

HIGH

CloudTrail multi-region trail is not enabled

Detection | Estimated effort: medium

What we observed

No multi-region CloudTrail trail was detected in the connected account.

Why this matters

Without a multi-Region trail, API activity in Regions outside the trail's coverage may be missing from the organization's ongoing audit record. That does not imply suspicious activity is occurring, but it can create a visibility gap that slows detection, investigation, and incident reconstruction if unauthorized or accidental changes occur in an uncovered Region.

TARGET STATE

Maintain an ongoing CloudTrail audit trail that covers activity across enabled AWS Regions.

WHERE TO GO IN AWS

CloudTrail -> Trails

BEFORE YOU START

- Confirm you have permission to create or update CloudTrail trails and manage the associated log destination.
- Confirm where CloudTrail logs should go: which S3 bucket to use, whether encryption is required, how long logs must be retained, and whether your organization centralizes CloudTrail logs.
- If you plan to convert an existing single-Region trail, identify that trail's home Region before using the CLI conversion command.
- Confirm the assessment boundary before remediation: this control verifies multi-Region trail presence only. Active logging, log-delivery health, and management-event configuration are recommended operational hardening checks, not states this control currently proves.

STEP-BY-STEP REMEDIATION

1. Open CloudTrail Trails and review existing trails before creating a duplicate logging path.
2. If creating a new trail in the CloudTrail console, create the trail with the approved S3 destination and required encryption or log-file validation settings; console-created trails provide multi-Region coverage.
3. If converting an existing single-Region trail, perform the conversion from that trail's home Region with the AWS CLI update-trail command using --is-multi-region-trail; the console does not convert an existing single-Region trail to multi-Region.
4. Ensure management-event logging is enabled according to the organization's audit requirements and start logging if it is not already active.

5. Confirm the trail details report multi-Region coverage and active logging.
6. Confirm the destination bucket is receiving new CloudTrail log objects before considering the operational hardening complete.

ADVANCED / OPTIONAL CLI

Optional for users comfortable with AWS CLI or CloudShell. The AWS Console procedure above remains the recommended default. Confirm the active AWS account and Region, replace every value in angle brackets with an environment-specific value, and review the expected configuration impact before execution.

Convert an existing trail to multi-Region coverage from its home Region

```
aws cloudtrail update-trail --name <trail-name> --is-multi-region-trail --region
<trail-home-region>
```

Ensure logging is running

```
aws cloudtrail start-logging --name <trail-name> --region <trail-home-region>
```

Important considerations

- Changing or duplicating CloudTrail destinations can affect retention, SIEM ingestion, alerting, and compliance workflows. Preserve required downstream integrations.

- Do not delete an existing trail until the replacement or converted trail is confirmed to be logging and downstream consumers are validated.

VERIFY IN AWS

1. Confirm CloudTrail shows at least one trail configured for multi-Region coverage; this is the AWS state required by the assessed control.
2. As additional operational hardening, confirm the selected trail is actively logging and recent log files are arriving at the intended destination.
3. Confirm management-event configuration, retention, and downstream consumers meet the organization's logging requirements; these additional states are not verified by the current assessment control.

Assessment success criteria

At least one CloudTrail trail is configured as a multi-Region trail.

Follow-up verification

After the AWS-side checks are complete, contact **Example Security Provider** through the stated contact channel when remediation is ready for verification. One follow-up point-in-time verification of remediated findings is included at no additional cost.

AWS Security Pillar context

Detection - Maintain traceability. Create a multi-Region CloudTrail trail to maintain an ongoing record of activity across all enabled AWS Regions.

OFFICIAL AWS GUIDANCE

Security best practices in AWS CloudTrail

ENGINEERING FINDING 2 OF 3

HIGH

IAM account password policy is not configured

Identity and access management | Estimated effort: low

What we observed

No IAM account password policy was found for the connected account.

Why this matters

A weak or absent IAM password policy can allow shorter, simpler, or repeatedly reused passwords. Those choices are generally more susceptible to password guessing, password spraying, credential-reuse attacks, or recovery if the same credential is exposed elsewhere. This finding does not mean an account has been compromised; it means an important layer of resistance to password-based attacks is below the assessed baseline. MFA remains an important additional safeguard for human identities.

TARGET STATE

Configure the IAM account password policy to meet the assessment baseline for IAM-user passwords.

WHERE TO GO IN AWS

IAM -> Account settings -> Password policy -> Edit

BEFORE YOU START

- Confirm you have permission to view and change the IAM account password policy.
- Capture the complete current password policy in IAM Account settings or with aws iam get-account-password-policy before changing it.
- Identify IAM users that still sign in with IAM passwords and review any organizational password requirements that are stricter than this assessment baseline.

STEP-BY-STEP REMEDIATION

1. Open IAM Account settings and compare the complete current Password policy with the assessment baseline and any stricter organizational requirements.
2. Record every current password-policy setting before making a change so an intentional setting is not accidentally reset.
3. Choose Edit password policy and set the minimum password length to at least 14 characters.
4. Require uppercase letters, lowercase letters, numbers, and non-alphanumeric symbols.
5. Enable password reuse prevention with a value greater than zero; use the organization’s required history value if it is stricter.
6. Set a maximum password age greater than zero according to organizational policy. The assessment baseline requires that a maximum age be configured but does not prescribe a specific number of days.

7. Review the complete resulting policy, including settings such as whether users may change their own passwords and hard expiry, then save only after every intended setting is explicit.

8. Confirm the intended values are active and continue to require MFA for human identities.

ADVANCED / OPTIONAL CLI

Optional for users comfortable with AWS CLI or CloudShell. The AWS Console procedure above remains the recommended default. Confirm the active AWS account and Region, replace every value in angle brackets with an environment-specific value, and review the expected configuration impact before execution.

Inspect the complete current IAM password policy before any CLI update

```
aws iam get-account-password-policy
```

Important considerations

- AWS UpdateAccountPasswordPolicy does not support partial updates. Any parameter omitted from an update reverts to its AWS default value, so do not use a shortened update command as though it patches only selected settings.

- If you use the AWS CLI to update the policy, explicitly define the complete intended policy state, including boolean choices such as whether users may change their own passwords and hard expiry. The console procedure above is safer when those choices have not already been decided.

- Password-policy changes affect IAM users that authenticate with IAM passwords. When a maximum password age is introduced, users whose current passwords are already older than that threshold can be required to change them at their next sign-in.

- Coordinate changes that may force password updates or disrupt established access procedures, and do not weaken a stricter organizational policy merely to match this baseline.

VERIFY IN AWS

1. Confirm IAM Account settings show minimum length 14 or greater, all four character requirements enabled, password reuse prevention configured, and a maximum password age configured.

2. Confirm retained IAM password users can complete any required password-change flow and authenticate as expected.

Assessment success criteria

IAM Account settings show a minimum password length of 14 or greater, uppercase, lowercase, number, and symbol requirements enabled, password reuse prevention configured, and a maximum password age configured.

Follow-up verification

After the AWS-side checks are complete, contact Example Security Provider through the stated contact channel when remediation is ready for verification. One follow-up point-in-time verification of remediated findings is included at no additional cost.

AWS Security Pillar context

Identity and access management - Implement a strong identity foundation. Where IAM user passwords remain in use, configure an account password policy that matches organizational requirements and combine strong passwords with MFA.

OFFICIAL AWS GUIDANCE

Set an account password policy for IAM users

ENGINEERING FINDING 3 OF 3

HIGH

S3 account-level Block Public Access is not configured

Data protection | Estimated effort: low

What we observed

No account-level S3 Public Access Block configuration was found for the connected account.

Why this matters

Missing account-level Block Public Access does not mean the account currently has a public bucket. It means an important preventive guardrail is absent, so a later bucket policy, ACL, or access-point configuration mistake has a greater chance of making S3 data publicly reachable. Depending on the data involved, that could lead to unintended disclosure of customer, operational, or proprietary information.

TARGET STATE

Enable all four Amazon S3 account-level Block Public Access guardrails where compatible with the account's intended workloads.

WHERE TO GO IN AWS

Amazon S3 -> Account and organization settings -> Block Public Access settings for this account -> Edit

BEFORE YOU START

- Confirm you have permission to modify the account-level S3 Block Public Access settings.
- Identify any buckets or access points that are intentionally designed for public access so those workloads can be tested before enforcement.
- Check whether an AWS Organizations S3 Block Public Access policy centrally controls this account; if it does, coordinate the change through the organization administrator.

STEP-BY-STEP REMEDIATION

1. Open S3 Account and organization settings and review the four effective account-level Block Public Access settings.
2. If the account setting is controlled by an AWS Organizations S3 Block Public Access policy and cannot be edited, coordinate with the organization administrator instead of attempting to override the policy locally.
3. Review intentionally public S3 workloads and determine whether they should remain public or move behind a controlled delivery mechanism such as CloudFront.
4. When the account setting is locally editable, choose Edit and enable BlockPublicAcls, IgnorePublicAcls, BlockPublicPolicy, and RestrictPublicBuckets.

5. Acknowledge the AWS confirmation, save the account-level settings, and test applications that read from or publish through S3.
6. Resolve unintended public-access dependencies rather than disabling the account-wide guardrail again where a safer architecture is available.

ADVANCED / OPTIONAL CLI

Optional for users comfortable with AWS CLI or CloudShell. The AWS Console procedure above remains the recommended default. Confirm the active AWS account and Region, replace every value in angle brackets with an environment-specific value, and review the expected configuration impact before execution.

Enable all four account-level controls when not centrally governed

```
aws s3control put-public-access-block --account-id <account-id>
--public-access-block-configuration
BlockPublicAcls=true,IgnorePublicAcls=true,BlockPublicPolicy=true,RestrictPublicBuckets=true
```

Important considerations

- Enabling account-level Block Public Access can intentionally break workloads that depend on public S3 access. Validate those designs before enforcement.

- An AWS Organizations S3 Block Public Access policy can prevent direct account-level changes; use the organization governance path when applicable.

- This finding does not prove that any current bucket is public; remediation adds the preventive account-level guardrail.

VERIFY IN AWS

1. Confirm all four effective S3 account-level Block Public Access settings are enabled, whether locally or through organization policy.
2. Confirm expected S3-dependent applications still function after the guardrail change.

Assessment success criteria

All four effective account-level S3 Block Public Access settings are enabled: BlockPublicAcls, IgnorePublicAcls, BlockPublicPolicy, and RestrictPublicBuckets.

Follow-up verification

After the AWS-side checks are complete, contact **Example Security Provider** through the stated contact channel when remediation is ready for verification. One follow-up point-in-time verification of remediated findings is included at no additional cost.

AWS Security Pillar context

Data protection - Protect data in transit and at rest. Use Amazon S3 Block Public Access controls at the account level to provide a broad guardrail against unintended public access to S3 resources.

OFFICIAL AWS GUIDANCE

Configuring block public access settings for your account

SANITIZED SAMPLE

APPENDIX

Assessment Evidence & Methodology

PASSED CONTROLS

- Root user MFA is enabled - Root sign-in credentials are present and the root user has MFA enabled.
- Root account access keys are not present - No active root account access keys are present.
- All IAM users have MFA enabled - All IAM users in the connected account have MFA enabled.
- No IAM access keys unused for 90 days or more were found - No active IAM user access keys have been unused for 90 days or more. Never-used keys younger than 90 days do not fail this control.
- No old IAM access keys were found - No active IAM user access keys are older than 90 days.
- No security groups expose SSH or RDP to the internet - No security groups across 17 enabled AWS Regions allow inbound SSH or RDP from 0.0.0.0/0 or ::/0.

METHODOLOGY

ASSESSMENT TYPE

Point-in-time

ACCESS MODEL

Read-only

Region scope

Account-global controls; SG: all 17 enabled Regions

Ruleset version

1.1

Control coverage

9 controls in the ruleset; 9 evaluated; 0 not applicable.

Assessment scope

This assessment evaluates selected foundational AWS security controls informed by AWS security guidance and the Security Pillar of the AWS Well-Architected Framework.

Framework scope

This is NOT a complete AWS Well-Architected Review.

Severity model

Severity uses AWS Security Hub terminology and priority meanings: CRITICAL, HIGH, MEDIUM, LOW, and INFORMATIONAL. AWS Security Coach assigns each finding's severity deterministically from its own ruleset; the label is not imported from Security Hub and is not an AWS-assigned severity for this assessment. CRITICAL requires immediate attention, HIGH is a priority, MEDIUM should be addressed but is not urgent, LOW has lower standalone urgency, and INFORMATIONAL indicates no confirmed security gap. This report may abbreviate INFORMATIONAL as INFO.

Assessment provider & contact

Assessment provider: Example Security Provider. Contact details are intentionally omitted from this sanitized portfolio sample.

Included follow-up verification

One follow-up point-in-time verification of remediated findings is included at no additional cost.